

DOCUMENTO TECNICO DI VALUTAZIONE

AEGIDA

POST-QUANTUM SECURITY FRAMEWORK

Architettura, Specifiche e Proposta di Valutazione

Per il Responsabile della Sicurezza Informatica e il Team Tecnico

DESTINATARI

CISO + Security Team

PROVENIENZA

tramite Responsabile Sicurezza

CLASSIFICAZIONE

Riservato — tecnico

DATA

Febbraio 2026

Il presente documento descrive l'architettura tecnica di AEGIDA, il suo posizionamento rispetto alle soluzioni esistenti e una proposta concreta di Proof of Concept su infrastruttura distribuita.

Contiene informazioni tecniche riservate relative a tecnologie proprietarie H4R.

La distribuzione è limitata ai destinatari autorizzati.

AEGIDA: Protezione delle Comunicazioni per Reti Distribuite ad Alta Criticità

AEGIDA è una piattaforma sviluppata da H4R per la protezione delle comunicazioni su reti geograficamente distribuite in contesti di infrastruttura critica. Implementa tre layer crittografici indipendenti — post-quantum key exchange, symmetric authenticated encryption e traffic obfuscation — su hardware industriale fanless progettato per operatività continua 24/7 in ambienti non presidiati.

Il posizionamento di AEGIDA è specifico: non sostituisce le soluzioni di sicurezza perimetrale o di identity management già in uso, ma aggiunge uno strato di protezione sul canale WAN che le soluzioni tradizionali — VPN, ZTNA, SD-WAN — strutturalmente non coprono. In particolare, affronta tre problemi che queste soluzioni non risolvono: la vulnerabilità agli attacchi store-now-decrypt-later, la rilevabilità del traffico cifrato tramite DPI e fingerprinting, e la mancanza di controllo granulare sugli accessi remoti di terze parti.

Contesto: Il Threat Landscape per Operatori di Rete Elettrica

Le infrastrutture di distribuzione elettrica sono tra gli obiettivi primari degli attori di minaccia avanzati a livello globale. Il vettore di attacco più documentato e sistematicamente sottovalutato non è l'impianto fisico, ma la rete di comunicazione che lo collega al centro di controllo.

Minacce specifiche documentate per il settore energetico

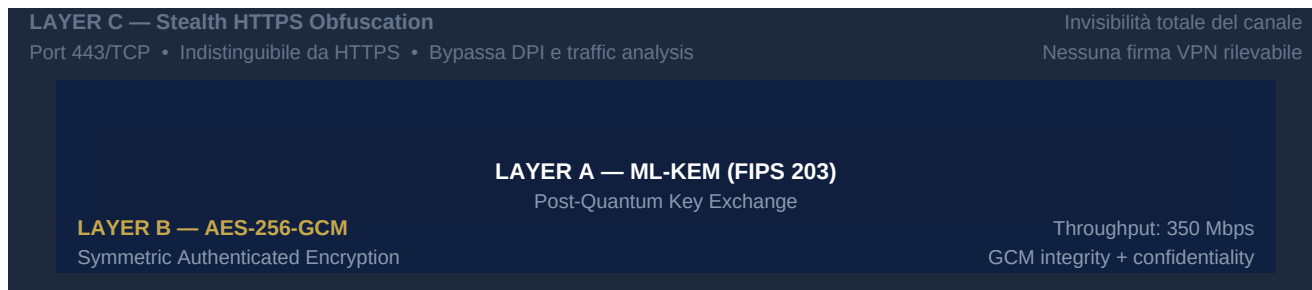
Campagna / Tecnica	Descrizione	Gap di sicurezza sfruttato
INDUSTROYER / CRASHOVERRIDE	ICS-specific malware utilizzato nell'attacco alla rete elettrica ucraina (2016). Propagazione iniziale via VPN compromessa di un fornitore OT. Lateralizzazione su protocolli IEC 60870-5-104 e IEC 61850.	Accesso remoto non segmentato + assenza di anomaly detection su traffico IEC
TRITON / TRISIS	Attacco ai Safety Instrumented System (SIS) di un impianto petrolchimico (2017). Framework malevolo deployato su engineering workstation raggiunta via movimenti laterali dalla rete IT.	Flat network IT/OT + accessi manutentori non monitorati
PIPEDREAM / INCONTROLLER	Toolkit ICS modulare (2022, attribuito a Sandworm/GRU) progettato esplicitamente per infrastrutture elettriche, gas e petrolio. Target: Schneider Electric e OMRON PLC. Capacità di disruption su scala nazionale.	PLC su rete OT raggiungibile via canali di gestione remota
Store-Now, Decrypt-Later	Raccolta massiva di traffico cifrato (SCADA, telecontrollo, configurazioni remote) da decriptare con computer quantistici futuri. NSA, NCSC UK e BSI hanno classificato questa minaccia come attiva e documentata.	Algoritmi classici (RSA/ECC) su link a lungo termine per infrastrutture 20-30 anni

Implicazione diretta per operatori con reti distribuite

La caratteristica comune di tutti gli attacchi documentati è la compromissione del **canale di comunicazione** come vettore iniziale o come mezzo di propagazione. La protezione dell'impianto fisico è necessaria ma non sufficiente: ogni link non protetto adeguatamente tra un sito remoto e il centro di controllo è un potenziale punto di ingresso.

Architettura Tecnica di AEGIDA

AEGIDA implementa tre layer di sicurezza indipendenti che operano simultaneamente su ogni pacchetto trasmesso. L'indipendenza funzionale tra i layer è una scelta architetturale deliberata: la compromissione di un layer non pregiudica la protezione offerta dagli altri due.



I tre layer operano simultaneamente e in modo indipendente su ogni pacchetto trasmesso

Dettaglio dei Layer Crittografici

Layer A — Post-Quantum Key Exchange: ML-KEM (NIST FIPS 203)

Parametro	Specifiche
Standard di riferimento	NIST FIPS 203 — finalizzato agosto 2024 (standard definitivo, non draft)
Algoritmo	Module Lattice-based Key Encapsulation Mechanism (ML-KEM), ex Kyber-768
Sicurezza classica	Equivalente a AES-192 contro attacchi classici
Sicurezza quantistica	Resistente ad attacchi con algoritmo di Shor su computer quantistici
Funzione specifica	Key encapsulation: generazione e scambio sicuro delle chiavi di sessione
Separazione architetturale	Il key exchange (Layer A) è funzionalmente separato dal data encryption (Layer B). Compromissione del canale non espone le chiavi pregresse (forward secrecy).
Protezione store-now-decrypt-later	Il traffico intercettato oggi rimane protetto anche con futuri quantum computer di potenza sufficiente a rompere RSA/ECC

Layer B — Symmetric Encryption: AES-256-GCM

Parametro	Specifiche
Algoritmo	AES-256 in modalità GCM (Galois/Counter Mode)
Authenticated Encryption	GCM garantisce simultaneamente confidenzialità, integrità e autenticità. Un pacchetto alterato in transito viene rilevato e scartato.
Throughput reale	350 Mbps con tutti e tre i layer attivi simultaneamente su hardware x86-64
Key derivation	Le chiavi AES sono derivate dal key material di Layer A. Rotation automatica per sessione. Nessuna chiave statica a lungo termine.
Forward secrecy	Ogni sessione utilizza chiavi effimere. La compromissione di una sessione non espone le sessioni pregresse o future.

Posizionamento rispetto alle Soluzioni Esistenti

AEGIDA non è un sostituto delle soluzioni di sicurezza perimetrale o di accesso remoto già in uso. È uno strato complementare e specializzato che risolve problemi specifici che le soluzioni tradizionali non affrontano strutturalmente.

Soluzione	Funzione primaria	Gap non coperti	Integrazione AEGIDA
IPSec / IKEv2 VPN	Cifratura del payload. Autenticazione peer.	Pattern VPN rilevabile via DPI. Nessuna protezione post-quantum nativa. Chiavi a lungo termine vulnerabili a store-now-decrypt-later.	AEGIDA aggiunge stealth layer e PQC. Può operare in parallelo o in sostituzione.
OpenVPN / WireGuard	Tunneling cifrato su UDP/TCP. WireGuard: performance elevate.	Firma di protocollo riconoscibile. Nessun PQC nativo (WireGuard ha roadmap PQC ma non ancora production-ready). Vulnerabile a fingerprinting.	Stessa integrazione di IPSec. AEGIDA aggiunge invisibilità e PQC.
ZTNA / Zero Trust Network Access	Accesso per identità verificata. Micro-segmentazione. Policy granulare per applicazione.	Non fornisce PQC. Non offre traffic obfuscation. Dipende da identity provider centralizzato.	Complementare: ZTNA gestisce l'identità, AEGIDA protegge il canale di trasporto.
SD-WAN	Ottimizzazione multi-path. Failover automatico. Visibilità applicativa sul traffico WAN.	Sicurezza tipicamente limitata a cifratura di trasporto. Nessun PQC. Traffic visible agli SD-WAN controller.	Integrabile: AEGIDA opera sotto l'SD-WAN overlay, proteggendo i flussi prima che raggiungano l'SD-WAN layer.
Firewall NGF / IDS-IPS	Ispezione traffico. Policy enforcement. Anomaly detection su pattern noti.	Non proteggono il canale WAN da intercettazione esterna. Operano su traffico già decifrato all'interno del perimetro.	Non sostitutivi. AEGIDA protegge il transito WAN; NGF/IDS operano nel perimetro interno.

Nota architetturale — nessun vendor lock-in

AEGIDA opera a livello di trasporto WAN e non richiede modifiche alla rete interna, alla policy di segmentazione, né ai sistemi di identity e access management esistenti. L'hardware è x86-64 standard: nessun lock-in su architetture proprietarie. Il logging è syslog-standard, integrabile con qualsiasi SIEM.

Rilevanza per l'Infrastruttura di Distribuzione ENEL

La rete di distribuzione elettrica italiana presenta caratteristiche infrastrutturali che rendono AEGIDA particolarmente rilevante rispetto a soluzioni di sicurezza generiche. I quattro scenari seguenti sono mappati sulla tipologia di infrastruttura tipica di un operatore di rete con migliaia di siti remoti su connettività eterogenea.

Caso d'uso	Scenario	Valore specifico AEGIDA
Protezione link remoti su 4G/LTE/WiMax	Centinaia/migliaia di cabine primarie e secondarie con link radio verso centri SCADA.	Layer stealth elimina fingerprinting. PQC protegge comandi di telecontrollo da intercettazione a lungo termine. Nessuna firma VPN rilevabile su link radio — riduce superficie di targeting.

Caso d'uso	Scenario	Valore specifico AEGIDA
Accesso remoto manutentori OEM	Fornitori di apparati (protezioni, trasformatori, RTU) con accesso remoto per manutenzione e diagnostica.	Accessi zero-trust temporizzati e tracciati. Nessun canale permanente. Whitelisting per fornitore specifico. Audit trail completo per NIS2. Contenimento: compromissione OEM non raggiunge rete OT.
Link inter-sito e datacenter	Connessioni tra control room, data center operativi e sedi distaccate.	Tunnel stealth su 443/TCP su qualsiasi link (fibra, LTE, satellite). Failover automatico multi-path. 350 Mbps reali con triplo layer attivo.
Protezione link satcom siti isolati	Impianti in aree remote con connettività esclusivamente satellitare.	Stealth layer riduce pattern riconoscibili su link sat a bassa capacità. PQC non aumenta overhead rispetto ad algoritmi classici. Multi-path per resilienza su link ad alta latenza.

Corrispondenza con Obblighi NIS2 / D.Lgs. 138/2024

Articolo NIS2	Requisito	Risposta AEGIDA
Art. 21 — Crittografia	Utilizzo della crittografia e cifratura E2E per la protezione dei dati in transito.	ML-KEM (FIPS 203) + AES-256-GCM. Conformità agli standard NIST più recenti.
Art. 21 — Gestione del rischio	Misure tecniche e organizzative proporzionate, inclusa la continuità operativa.	Mesh ridondante, failover automatico, nessun SPOF. Deployment trasparente.
Art. 21 — Sicurezza supply chain	Controllo degli accessi di fornitori e terze parti alla rete operativa.	Accessi OEM zero-trust, temporizzati, tracciati. Audit log verificabile.
Artt. 20-23 — Governance e audit	Capacità di dimostrare l'adeguatezza delle misure adottate ad ACN.	Logging strutturato, audit trail completo, evidenze tecniche verificabili da SIEM.

Proposta di Proof of Concept

La proposta di PoC è strutturata per rispettare i requisiti tipici di un operatore di infrastruttura critica: nessun impatto sulla continuità operativa, perimetro limitato e non critico per la fase iniziale, processo formale di vendor qualification, KPI pre-definiti e misurabili.

Struttura del PoC — Tre Fasi

FASE Setup e Vendor Qualification (settimane 1-3)

Firma NDA tecnico. Avvio processo di vendor qualification secondo le procedure interne. Consegna documentazione tecnica completa (datasheet, schema architetturale, risultati test di laboratorio, certificazioni in corso). Definizione del perimetro di PoC e dei KPI con il team tecnico ENEL. Provisioning dell'ambiente di test.

FASE Deployment e Test (settimane 4-10)

Installazione AEGIDA Gateway sul perimetro concordato in modalità bridge trasparente. Verifica throughput reale e latenza aggiuntiva sul link. Test di resistenza a DPI su traffico reale (con strumenti del team tecnico ENEL). Test di failover multi-path e tempo di convergenza. Test di accesso OEM temporizzato e revoca. Verifica logging e integrazione con SIEM/Syslog esistente.

FASE Analisi Risultati e Decisione (settimane 11-14)

Report tecnico con KPI misurati vs KPI attesi. Assessment della complessità di deployment su scala (da 1 sito a N siti). Stima effort di integrazione con stack esistente. Presentazione al CISO e al team di sicurezza. Decisione go/no-go su eventuale deployment esteso.

Perimetri Consigliati per la Fase di PoC

Perimetro	Rischio operativo	Razionale
Link office → datacenter operativo	Basso	Link ad alta disponibilità tra sede e DC. Nessun impatto su OT. Ideale per test throughput e DPI resistance su traffico reale.
Singolo accesso OEM remoto	Basso	Un fornitore specifico su un impianto non critico. Test completo del workflow zero-trust: provisioning, accesso, revoca, audit.
Ambiente di test dedicato	Nulla	Replica dell'architettura di produzione in ambiente isolato. Massima libertà di test. Richiede setup aggiuntivo ma nessun rischio operativo.
Cabina secondaria pilota	Medio	Un sito remoto su link LTE/WiMax. Test del caso d'uso principale. Richiede approvazione IT/OT security e coordinamento con O&M; locale.

Condizioni operative del PoC

Il PoC proposto è un'attività a pagamento: la messa a disposizione dell'appliance, il supporto tecnico on-site e da remoto, e la redazione del report finale sono inclusi in un contratto di valutazione con corrispettivo definito. Un PoC gratuito non è nell'interesse di nessuna delle due parti: riduce la qualità del supporto e il livello di impegno reciproco. Il corrispettivo viene concordato prima dell'avvio e non comporta alcun impegno successivo di acquisto.

KPI Proposti per la Valutazione

KPI	Metrica	Target
Throughput netto	Misurato vs dichiarato (350 Mbps)	≥ 300 Mbps su link di test a piena capacità
Latenza aggiuntiva	Overhead del triplo layer su RTT baseline	< 5 ms di overhead su link fibra; < 15 ms su link LTE
DPI resistance	Rilevamento tunnel su campione di appliance NGF	0% rilevamento su almeno 3 strumenti di ispezione diversi
Failover time	Tempo di convergenza su link multipli	< 30 secondi su doppio link attivo/standby
Audit completeness	Copertura degli accessi nel log	100% degli accessi OEM tracciati con timestamp, durata, protocollo
SIEM integration	Ingestione log in formato standard	Syslog CEF o JSON su protocollo standard; zero custom parsing

Roadmap verso Certificazioni Formali

Certificazione	Scope	Timeline	Stato
NIST FIPS 203	ML-KEM	Standard definitivo — agosto 2024	Algoritmo già implementato conforme allo standard
FIPS 140-3	Modulo crittografico	Validazione prevista 2025-2026	Processo di validazione avviabile contestualmente al PoC
Common Criteria EAL4+	Piattaforma completa	24-36 mesi	Necessario per procurement PA e defense — in roadmap
ACN Qualificazione	Per supply chain PA italiana	12-18 mesi	Prerequisito per contratti con soggetti NIS2 Essential

Passi Successivi

Il confronto tecnico con il team H4R è aperto: siamo disponibili a discutere l'architettura in dettaglio, a esaminare il vostro stack di sicurezza esistente per identificare dove AEGIDA si inserisce, e a definire insieme le condizioni e il perimetro del PoC.

- 1 Incontro tecnico con il team H4R (in presenza o remoto) — durata: 90-120 minuti
- 2 Consegna del datasheet tecnico completo e dei risultati di test di laboratorio
- 3 Definizione congiunta del perimetro di PoC e dei KPI
- 4 Firma NDA tecnico e avvio processo di vendor qualification
- 5 Proposta commerciale per il PoC e firma del contratto di valutazione

H4R Human for Research — Riferimenti

Il team tecnico H4R è a disposizione per approfondimenti su qualsiasi aspetto dell'architettura: schemi di deployment, risultati dei test di interoperabilità, documentazione algoritmica dettagliata. Tutto disponibile sotto NDA, su richiesta.

Documento riservato — distribuzione limitata ai destinatari designati. Documentazione tecnica aggiuntiva disponibile sotto NDA su richiesta.